

Reglas de la prueba de Librería Fiordo

PF1495 · Hacking Ético en Aplicativos Web

Módulo 2 · MA03807 · Introducción al hacking ético

MODALIDAD

Grupal, de 4 a 5 personas.

APRENDIZAJE ESPERADO 2

Analizar las características del hacking ético, código ético, marco legal y normas de la industria para la protección de los sistemas informáticos.

CRITERIOS DE EVALUACIÓN

- 2.1 Identifica las características principales del hacking ético, principios y principales metodologías y certificaciones de la industria.
- 2.2 Describe el marco legal y ético al cual se circunscriben las prácticas del hacking ético identificando las principales leyes relacionadas con la protección de datos.
- 2.3 Explica las principales características y alcances de las normas y estándares de la industria para el hacking ético

Contexto

Con el mapa de amenazas del ABPRO anterior, la gerencia de Librería Fiordo (empresa ficticia) quiere seguir adelante con la prueba. Antes de firmar, su abogada pide entender en qué marco ético, legal y normativo trabajará el equipo.

Problema

La librería guarda nombres, correos, direcciones y pedidos de sus clientes, y su tienda usa un proveedor de pagos externo. La abogada pregunta: ¿qué pasa si el equipo ve datos personales?, ¿quién responde si la tienda se cae durante la prueba?, ¿puede el equipo probar también el sistema del proveedor de pagos?

Solución

Un documento de **reglas de la prueba** que la abogada pueda revisar: los principios del equipo, el marco legal y ético, las normas de la industria que se seguirán y un borrador de autorización con el alcance.

Desarrollo

- 1. Principios y metodología.** Expliquen los principios del hacking ético que guiarán al equipo, un hito de la historia del hacking ético que les parezca relevante y qué metodologías y certificaciones dan confianza a la librería (criterio 2.1).
- 2. Marco legal.** Expliquen qué implican para la prueba las leyes contra el acceso no autorizado (Ley 21.459), de protección de datos (Ley 19.628 y su reforma), de propiedad intelectual y

los tratados de cooperación internacional. Respondan las tres preguntas de la abogada (criterio 2.2).

3. **Códigos de ética.** Comparen los códigos de EC-Council y del Instituto SANS y elijan tres compromisos que el equipo adopta, con un ejemplo de cómo se aplican en la tienda (criterio 2.2).
4. **Normas de la industria.** Expliquen cómo se relacionan con la prueba ISO/IEC 27001, NIST SP 800-53 y OWASP TG, y cuál usarán para ordenar las pruebas web (criterio 2.3).
5. **Borrador de autorización.** Redacten el alcance: qué se prueba y qué no (el proveedor de pagos queda fuera), quién autoriza por escrito, cómo se tratan los datos personales, qué se hace con la evidencia y cuándo se detiene la prueba.
6. **Debate.** Tomen posición en 5 a 8 líneas: ¿debería tratarse distinto a quien encuentra una falla sin autorización y la informa sin pedir nada a cambio?
7. **Resumen para el foro.** El portavoz publica un resumen de una página o un video breve con las reglas clave de la prueba.

Roles del equipo

Roten los roles respecto del ABPRO anterior:

- **Coordinador/a:** organiza el trabajo y cuida que todos participen.
- **Responsable legal:** conduce el marco legal y las respuestas a la abogada.
- **Responsable de ética y normas:** conduce los códigos de ética y las normas de la industria.
- **Documentador/a:** redacta el borrador de autorización y la entrega.
- **Portavoz:** prepara el resumen para el foro. En equipos de 4, el documentador/a asume también este rol.

Entrega

Una entrega por equipo en esta Tarea: un PDF con los principios, el marco legal, los compromisos éticos, las normas, el borrador de autorización, la posición del debate, el enlace al resumen del foro y los nombres de los integrantes con su rol.